

Application Security Verification Standard

Version 5.0.0



May 2025

Contents

Frontispiece	7
About the Standard	7
Copyright and License	7
Project Leads	7
Working Group	7
Other Major Contributors	7
Other Contributors and Reviewers	8
Preface	8
Introduction	8
Principles behind version 5.0	8
Looking ahead	9
What is the ASVS?	9
Scope of the ASVS	9
Application	10
Security	10
Verification	10
Standard	10
Requirement	11
Documented security decisions	11
Application Security Verification Levels	12
Level evaluation	13
Level 1	13
Level 2	13
Level 3	14
Which level to achieve	14
How to use the ASVS	14
The structure of the ASVS	14
Release strategy	14
Flexibility with the ASVS	15
How to Reference ASVS Requirements	15
Forking the ASVS	16
Use cases for the ASVS	16
As Detailed Security Architecture Guidance	16
As a Specialized Secure Coding Reference	16
As a Guide for Automated Unit and Integration Tests	17
For Secure Development Training	17
As a Framework for Guiding the Procurement of Secure Software	17
Applying ASVS in Practice	17

Assessment and Certification	18
OWASP's Stance on ASVS Certifications and Trust Marks	18
How to Verify ASVS Compliance	18
Verification reporting	18
Scope of Verification	18
Verification Mechanisms	19
Changes Compared to v4.x	20
Introduction	20
Requirement Philosophy	20
Scope and Focus	20
Emphasis on Security Goals Over Mechanisms	20
Documented Security Decisions	20
Structural Changes and New Chapters	21
Removal of Direct Mappings to Other Standards	21
Reduced Coupling with NIST Digital Identity Guidelines	22
Moving Away from Common Weakness Enumeration (CWE)	22
Rethinking Level Definitions	22
Easier Entry Level	22
The Fallacy of Testability	22
Not Just About Risk	23
V1 Encoding and Sanitization	23
Control Objective	23
V1.1 Encoding and Sanitization Architecture	23
V1.2 Injection Prevention	24
V1.3 Sanitization	25
V1.4 Memory, String, and Unmanaged Code	27
V1.5 Safe Deserialization	27
References	28
V2 Validation and Business Logic	28
Control Objective	28
V2.1 Validation and Business Logic Documentation	29
V2.2 Input Validation	29
V2.3 Business Logic Security	30
V2.4 Anti-automation	31
References	31
V3 Web Frontend Security	32
Control Objective	32
V3.1 Web Frontend Security Documentation	32

V3.2 Unintended Content Interpretation	32
V3.3 Cookie Setup	33
V3.4 Browser Security Mechanism Headers	33
V3.5 Browser Origin Separation	35
V3.6 External Resource Integrity	36
V3.7 Other Browser Security Considerations	37
References	37
V4 API and Web Service	38
Control Objective	38
V4.1 Generic Web Service Security	38
V4.2 HTTP Message Structure Validation	39
V4.3 GraphQL	40
V4.4 WebSocket	40
References	41
V5 File Handling	41
Control Objective	41
V5.1 File Handling Documentation	41
V5.2 File Upload and Content	42
V5.3 File Storage	42
V5.4 File Download	43
References	43
V6 Authentication	44
Control Objective	44
V6.1 Authentication Documentation	44
V6.2 Password Security	45
V6.3 General Authentication Security	46
V6.4 Authentication Factor Lifecycle and Recovery	47
V6.5 General Multi-factor authentication requirements	48
V6.6 Out-of-Band authentication mechanisms	49
V6.7 Cryptographic authentication mechanism	50
V6.8 Authentication with an Identity Provider	51
References	52
V7 Session Management	52
Control Objective	52
V7.1 Session Management Documentation	53
V7.2 Fundamental Session Management Security	53
V7.3 Session Timeout	54
V7.4 Session Termination	54

V7.5 Defenses Against Session Abuse	55
V7.6 Federated Re-authentication	56
References	56
V8 Authorization	56
Control Objective	56
V8.1 Authorization Documentation	57
V8.2 General Authorization Design	57
V8.3 Operation Level Authorization	58
V8.4 Other Authorization Considerations	58
References	59
V9 Self-contained Tokens	59
Control Objective	59
V9.1 Token source and integrity	59
V9.2 Token content	60
References	61
V10 OAuth and OIDC	61
Control Objective	61
V10.1 Generic OAuth and OIDC Security	63
V10.2 OAuth Client	63
V10.3 OAuth Resource Server	64
V10.4 OAuth Authorization Server	65
V10.5 OIDC Client	67
V10.6 OpenID Provider	68
V10.7 Consent Management	68
References	69
V11 Cryptography	70
Control Objective	70
V11.1 Cryptographic Inventory and Documentation	70
V11.2 Secure Cryptography Implementation	71
V11.3 Encryption Algorithms	72
V11.4 Hashing and Hash-based Functions	73
V11.5 Random Values	73
V11.6 Public Key Cryptography	74
V11.7 In-Use Data Cryptography	74
References	75
V12 Secure Communication	75
Control Objective	75
V12.1 General TLS Security Guidance	75

V12.2 HTTPS Communication with External Facing Services	76
V12.3 General Service to Service Communication Security	76
References	77
V13 Configuration	77
Control Objective	77
V13.1 Configuration Documentation	78
V13.2 Backend Communication Configuration	78
V13.3 Secret Management	79
V13.4 Unintended Information Leakage	80
References	81
V14 Data Protection	81
Control Objective	81
V14.1 Data Protection Documentation	81
V14.2 General Data Protection	82
V14.3 Client-side Data Protection	83
References	84
V15 Secure Coding and Architecture	84
Control Objective	84
V15.1 Secure Coding and Architecture Documentation	84
V15.2 Security Architecture and Dependencies	85
V15.3 Defensive Coding	86
V15.4 Safe Concurrency	87
References	88
V16 Security Logging and Error Handling	88
Control Objective	88
V16.1 Security Logging Documentation	89
V16.2 General Logging	89
V16.3 Security Events	90
V16.4 Log Protection	91
V16.5 Error Handling	91
References	92
V17 WebRTC	92
Control Objective	92
V17.1 TURN Server	93
V17.2 Media	93
V17.3 Signaling	95
References	95

Appendix A: Glossary	96
Appendix B: References	102
OWASP Core Projects	102
OWASP Cheat Sheet Series project	102
Mobile Security Related Projects	102
OWASP Internet of Things related projects	102
OWASP Serverless projects	102
Others	102
Appendix C: Cryptography Standards	103
Cryptographic Inventory and Documentation	103
Equivalent Strengths of Cryptographic Parameters	104
Random Values	104
Cipher Algorithms	105
AES Cipher Modes	106
Key Wrapping	107
Authenticated Encryption	107
Hash Functions	108
Hash Functions for General Use Cases	108
Hash Functions for Password Storage	111
Key Derivation Functions (KDFs)	112
General Key Derivation Functions	112
Password-based Key Derivation Functions	112
Key Exchange Mechanisms	113
KEX Schemes	113
Diffie-Hellman groups	113
Message Authentication Codes (MAC)	114
Digital Signatures	115
Post-Quantum Encryption Standards	116
Appendix D: Recommendations	116
Introduction	116
Recommended, in-scope mechanisms	116
Software Security principles	117
Software Security processes	117
Appendix E - Contributors	118

Frontispiece

About the Standard

The Application Security Verification Standard is a list of application security requirements that architects, developers, testers, security professionals, tool vendors, and consumers can use to define, build, test, and verify secure applications.

Copyright and License

Version 5.0.0, May 2025



Figure 1: license

Copyright © 2008-2025 The OWASP Foundation.

This document is released under the Creative Commons Attribution-ShareAlike 4.0 International License.

For any reuse or distribution, you must clearly communicate the license terms of this work to others.

Project Leads

Elar Lang	Josh C Grossman
Jim Manico	Daniel Cuthbert

Working Group

Tobias Ahnoff	Ralph Andalis	Ryan Armstrong	Gabriel Corona
Meghan Jacquot	Shanni Prutchi	Iman Sharafaldin	Eden Yardeni

Other Major Contributors

Sjoerd Langkemper	Isaac Lewis
-------------------	-------------

Mark CarneySandro Gauci

Other Contributors and Reviewers

We have included a list of the other contributors in Appendix E.

If a credit is missing from the 5.x credit list, please log a ticket at GitHub to be recognized in future 5.x updates.

The Application Security Verification Standard builds on the work of those involved in ASVS 1.0 (2008) through 4.0 (2019). Much of the structure and many of the verification items that remain in ASVS today were originally written by Andrew van der Stock, Mike Boberski, Jeff Williams, and Dave Wichers, among numerous other contributors. Thank you to everyone who has contributed in the past. For a comprehensive list of earlier contributors, please consult each prior version.

Preface

Welcome to the Application Security Verification Standard (ASVS) Version 5.0.

Introduction

Originally launched in 2008 through a global community collaboration, the ASVS defines a comprehensive set of security requirements for designing, developing, and testing modern web applications and services.

Following the release of ASVS 4.0 in 2019 and its minor update (v4.0.3) in 2021, Version 5.0 represents a significant milestone—modernized to reflect the latest advances in software security.

ASVS 5.0 is the result of extensive contributions from project leaders, working group members, and the wider OWASP community to update and improve this important standard.

Principles behind version 5.0

This major revision has been developed with several key principles in mind:

- **Refined Scope and Focus:** This version of the standard has been designed to align more directly with the foundational pillars in its name: Application, Security, Verification, and Standard. Requirements have been rewritten to emphasize the prevention of security flaws rather than mandating specific technical implementations. Requirement texts are intended to be self-explanatory, explaining why they exist.

- **Support for Documented Security Decisions:** ASVS 5.0 introduces requirements for documenting key security decisions. This enhances traceability and supports context-sensitive implementations, allowing organizations to tailor their security posture to their specific needs and risks.
- **Updated Levels:** While ASVS retains its three-tier model, the level definitions have evolved to make the ASVS easier to adopt. Level 1 is designed as the initial step to adopting the ASVS, providing the first layer of defense. Level 2 represents a comprehensive view of standard security practices, and Level 3 addresses advanced, high-assurance requirements.
- **Restructured and Expanded Content:** ASVS 5.0 includes approximately 350 requirements across 17 chapters. Chapters have been reorganized for clarity and usability. A two-way mapping between v4.0 and v5.0 is provided to facilitate migration.

Looking ahead

Just as securing an application is never truly finished, neither is the ASVS. Although Version 5.0 is a major release, development continues. This release allows the wider community to benefit from the improvements and additions which have been accumulated but also lays the groundwork for future enhancements. This could include community-driven efforts to create implementation and verification guidance built on top of the core requirement set.

ASVS 5.0 is designed to serve as a reliable foundation for secure software development. The community is invited to adopt, contribute, and build upon this standard to collectively advance the state of application security.

What is the ASVS?

The Application Security Verification Standard (ASVS) defines security requirements for web applications and services, and it is a valuable resource for anyone aiming to design, develop, and maintain secure applications or evaluate their security.

This chapter outlines the essential aspects of using the ASVS, including its scope, the structure of its priority-based levels, and the primary use cases for the standard.

Scope of the ASVS

The scope of the ASVS is defined by its name: Application, Security, Verification, and Standard. It establishes which requirements are included or excluded, with the overarching goal of identifying the security principles that must be achieved. The scope also considers documentation requirements, which serve as the foundation for implementation requirements.